Arquitectura Passkeys para Combos Alimenticios

VERSIÓN 2.0 | OFFLINE-FIRST

Resumen Ejecutivo de Producto, Seguridad, Operación Offline y Gobernanza

OCTUBRE 2026

1. Visión Estratégica y Caso de Negocio

La plataforma tiene como objetivo optimizar el registro, reserva, validación y entrega presencial de combos alimenticios en instalaciones corporativas e industriales. Mediante el uso de autenticación biométrica nativa con **Passkeys (FIDO2/WebAuthn)** y una arquitectura **Offline-First**, se elimina por completo el fraude por suplantación de identidad y se garantiza la continuidad de la operación en comedores subterráneos o sitios remotos sin señal celular.

Cero Suplantación Validación asimétrica ligada al chip del teléfono.	**Atención < 3 Segundos** Escaneo de QR dinámico y validación local.	**Operación 100% Offline** Base de datos SQLite y firma en hardware.

2. Arquitectura de Seguridad con Passkeys (FIDO2)

El sistema utiliza la especificación W3C WebAuthn / FIDO2 para la autenticación sin contraseñas:

- **Aislamiento en Hardware:** La biometría (Face ID / Huella) se procesa exclusivamente dentro del Secure Enclave (iOS) o TEE (Android). Los datos biométricos crudos jamás abandonan el dispositivo.
- **Criptografía Asimétrica (ECDSA P-256):** La llave privada permanece encriptada en el teléfono. La llave pública correspondiente se registra en la base de datos central.
- **QR Dinámico Firmado:** La App del trabajador firma digitalmente un paquete local con ID_Trabajador + ID_Combo + Timestamp + Nonce (32 bytes), generando un código QR dinámico que expira en 60 segundos.
- **Inmunidad contra Replay Attacks:** Cada firma incluye un desafío único (nonce) que previene ataques de interceptación o capturas de pantalla.

> **GARANTÍA DE SEGURIDAD CRIPTOGRÁFICA**
>
> La Passkeys no puede ser transferida por WhatsApp ni compartida entre compañeros de trabajo, garantizando la irrefutabilidad de la entrega presencial.

3. Operación Offline-First en 4 Fases

Fase	Descripción Operativa	Mecanismo Técnico
1. Precarga Diaria	La App del distribuidor descarga el padrón activo al iniciar el día.	Almacenamiento en SQLite local (SQLCipher).
2. Validación Local	El distribuidor escanea el QR dinámico firmado del trabajador.	Verificación asimétrica con la llave pública en SQLite (sin red).
3. Sync Queue	La entrega se aprueba en pantalla y se guarda en cola diferida.	Registro con UUIDv4 e is_offline_sync = true.
4. Reconciliación	Al detectar conexión, la App transmite los registros acumulados.	Backend ejecuta la regla única idx_unique_daily_claim.

4. Gobernanza de Nómina y Matriz de Contingencias

La base de datos se mantiene sincronizada con el sistema de Nómina/RRHH (SAP, Workday) mediante Webhooks en tiempo real o cargas SFTP batch. Ante bajas de personal, el sistema ejecuta un **Kill-Switch** que revoca inmediatamente las credenciales Passkeys y cancela los derechos del día.

Mecanismo	Caso de Uso	Aprobación & Auditoría
Tarjeta NFC / RFID	Trabajadores sin smartphone (has_smartphone = false) o contratistas.	Asignación de UID físico ligado al trabajador en tabla nfc_cards.
Liberación Manual Supervisada	Teléfono extraviado, robado o con batería descargada.	**Firma Biométrica Obligatoria de Supervisor** (Nivel 2) + motivo textual.
Re-enrolamiento	Adquisición de nuevo dispositivo celular.	Inactivación de llave anterior y enrolamiento de nuevo par FIDO2.

5. Esquema Relacional de BD y Contrato API REST

- **Entidades Principales (PostgreSQL):** workers, passkey_credentials, nfc_cards, combos, daily_entitlements, distribution_points y deliveries.
- **Restricción de Anti-Duplicado Diario:** CREATE UNIQUE INDEX idx_unique_daily_claim ON deliveries (worker_id, entitlement_id); garantiza que no se pueda entregar un combo dos veces el mismo día por ningún método.
- **APIs REST Clave:** Webhooks de nómina (POST /api/v1/payroll/webhook), descarga de datos offline (GET /api/v1/sync/daily-pack) y sincronización en lote (POST /api/v1/sync/batch-deliveries).

6. Plan de Implementación (12 Semanas)

Fase	Duración	Entregables Clave
Fase 1: Core Backend & DB	Semanas 1 - 3	Esquema PostgreSQL, servidor FIDO2/WebAuthn, APIs REST e ingesta de nómina.
Fase 2: App Trabajador	Semanas 4 - 6	Onboarding biométrico Passkeys, vista de combos y generador de QR dinámico.
Fase 3: App Distribuidor & Offline	Semanas 7 - 9	Escáner QR, motor SQLite local, validación de firmas offline y cola Sync Queue.
Fase 4: Pruebas & Pilotaje	Semanas 10 - 12	Pruebas de estrés offline, auditoría de penetración y despliegue piloto en planta.